HEPIA – Haute École du Paysage, d'Ingénierie et d'Architecture

Filière ISC – Informatique et Systèmes de Communication

Genève, Suisse

RAPPORT DE SYNTHÈSE

Infrastructure PME Sécurisée

Projet SecOS-GR8

Sécurité des Systèmes d'Exploitation

Étudiants : HYSENI Riad
EL HAKOUNI Yassin

Professeur : Lionel Brocard

Cours : Sécurité des Systèmes d'Exploitation

Semestre : Printemps 2025-26

Groupe : Groupe 8

Date de rendu : 05 janvier 2026

Infrastructure virtualisée sur Proxmox – Réseau 192.168.100.0/24

1 Introduction

1.1 Contexte du projet

Dans le cadre du cours de Sécurité des Systèmes d'Exploitation dispensé à HEPIA, nous devons concevoir, déployer et sécuriser une infrastructure informatique complète simulant l'environnement d'une PME. L'infrastructure déployée répond aux besoins typiques d'une entreprise : gestion des identités, stockage de fichiers, sauvegardes, accès VPN, web, messagerie et centralisation des logs.

1.2 Objectifs

- Concevoir une architecture réseau cohérente et sécurisée
- Déployer les dix services essentiels d'une infrastructure PME
- Appliquer un durcissement avancé sur les sept serveurs critiques
- Maintenir une sécurité de base sur les trois serveurs auxiliaires
- Garantir l'interopérabilité des services après durcissement
- Documenter les configurations et procédures

1.3 Périmètre

L'infrastructure comprend **dix machines virtuelles** Debian 12 déployées sur Proxmox, interconnectées via le réseau 192.168.100.0/24 avec le domaine `secos-gr8.lan`. L'accès externe s'effectue via un point relais SSH.

2 Architecture de l'Infrastructure

2.1 Vue d'ensemble

L'infrastructure est composée de dix serveurs virtualisés répartis en deux catégories : sept serveurs critiques avec durcissement avancé (audité par Lynis), et trois serveurs auxiliaires avec sécurité standard.

Serveur	IP	Service	Fonction	Sécurité
ADMIN	192.168.100.120	SSH Bastion	Point d'entrée sécurisé	Standard
DNS	192.168.100.136	Unbound	Résolution DNS interne	Standard
AUTH	192.168.100.139	OpenLDAP	Annuaire centralisé	**Avancée**
DATA	192.168.100.149	Samba/SFTP	Partage de fichiers	**Avancée**
BACKUP	192.168.100.151	rsnapshot	Sauvegardes automatisées	**Avancée**
VPN	192.168.100.153	WireGuard	Accès distant sécurisé	**Avancée**
WEB	192.168.100.157	Nginx	Serveur web HTTPS	**Avancée**
CLIENT	192.168.100.159	Xfce GUI	Poste de test	Standard
MAIL	192.168.100.162	Postfix/Dovecot	Messagerie électronique	**Avancée**
LOGS	192.168.100.176	rsyslog	Centralisation des journaux	**Avancée**

Table 1 – Inventaire complet des 10 serveurs de l'infrastructure

2.2 Topologie réseau

Tous les serveurs communiquent sur le réseau 192.168.100.0/24. Le DNS Unbound assure la résolution des noms internes. Les communications SSH utilisent l'authentification par clé Ed25519. Le VPN WireGuard offre un accès distant sur le réseau 10.10.10.0/24. Le serveur LOGS centralise les journaux via syslog (UDP/514).

3 Services Déployés

3.1 Services avec sécurité avancée (7 VMs)

Ces serveurs ont bénéficié d'un durcissement complet (Lynis, Fail2ban, Auditd, SSH renforcé, kernel hardening) avec des scores Lynis supérieurs à 77/100.

AUTH – OpenLDAP (192.168.100.139) : Annuaire centralisé avec base DN `dc=secos-gr8,dc=lan`. Gère les utilisateurs et groupes de l'organisation. Ports ouverts : 22 (SSH), 389 (LDAP). Tous les autres ports sont bloqués par UFW.

DATA – Samba/SFTP (192.168.100.149) : Serveur de fichiers offrant un partage SMB (ports 445, 139) pour les postes clients et SFTP (port 22) pour les transferts sécurisés. Le partage `company` est accessible au groupe `smbusers`.

BACKUP – rsnapshot (192.168.100.151) : Système de sauvegardes incrémentales avec rétention de 7 quotidiennes, 4 hebdomadaires et 3 mensuelles. Sauvegarde automatique du serveur DATA via SSH chaque nuit à 2h00. Seul le port SSH est ouvert.

VPN – WireGuard (192.168.100.153) : Tunnel VPN sur le réseau 10.10.10.0/24 (port 51820/UDP). Deux peers configurés pour l'accès distant. Le routage IP (ip_forward=1) est activé sur cette VM uniquement.

WEB – Nginx (192.168.100.157) : Serveur web avec redirection HTTP vers HTTPS, certificat TLS auto-signé et en-têtes de sécurité (HSTS, X-Frame-Options, X-Content-Type-Options). Ports 80 et 443 ouverts.

MAIL – Postfix/Dovecot (192.168.100.162) : Infrastructure de messagerie complète. Postfix gère l'envoi (SMTP ports 25, 587), Dovecot la réception (IMAP 143/993, POP3 110/995). Format Maildir.

LOGS – rsyslog (192.168.100.176) : Serveur de centralisation des journaux. Reçoit les logs via UDP/514 (non chiffré) et TCP/6514 avec **TLS activé** (gtls). Logs organisés par hostname dans `/var/log/remote/`.

3.2 Services avec sécurité standard (3 VMs)

Ces serveurs disposent d'une sécurité de base (pare-feu UFW, AppArmor, SSH par clé) mais n'ont pas reçu le durcissement complet. Aucun audit Lynis n'a été réalisé sur ces VMs. Ils restent néanmoins significativement plus sécurisés qu'une installation Debian par défaut.

ADMIN – Bastion SSH (192.168.100.120) : Point d'entrée pour l'administration de l'infrastructure. Le pare-feu UFW est configuré en mode "deny" par défaut, seul le port SSH (22) est ouvert. Tous les autres ports (80, 443, 25, etc.) sont bloqués.

DNS – Unbound (192.168.100.136) : Serveur DNS récursif avec cache, gérant la zone locale `secos-gr8.lan`. Ports ouverts : 53/UDP, 53/TCP (DNS) et 22 (SSH). Le serveur ne répond qu'aux requêtes du réseau interne.

CLIENT – Poste de test (192.168.100.159) : Machine avec interface graphique Xfce pour tester les services déployés (accès web, Samba, VPN). Seul le port SSH est ouvert. Outils installés : firefox-esr, smbclient, wireguard-tools.

4 Stratégie de Sécurisation

4.1 Approche différenciée

Notre stratégie distingue deux niveaux : durcissement complet pour les 7 serveurs critiques, sécurité standard pour les 3 serveurs auxiliaires.

4.2 Mesures de sécurité avancée (7 VMs)

- **Outils installés :** Lynis, Fail2ban, Auditd, libpam-pwquality, unattended-upgrades
- **SSH durci :** Clé Ed25519, root désactivé, algorithmes modernes, 3 tentatives max, bannière d'avertissement légal
- **Fail2ban :** Ban 1h après 3 échecs SSH
- **Kernel :** SYN cookies, anti-spoofing, ASLR, restriction dmesg/kptr
- **Auditd :** Surveillance passwd/shadow, sudo/su, modules kernel
- **Modules désactivés :** dccp, sctp, rds, tipc, cramfs, hfs
- **rsyslog TLS :** Serveur LOGS configuré avec certificats x509 (port 6514)

4.3 Mesures de sécurité standard (3 VMs)

- Pare-feu UFW actif (policy deny)
- AppArmor activé
- SSH par clé configuré
- Ports limités aux services nécessaires

4.4 Résultats des audits Lynis

L'outil Lynis a permis de valider objectivement le niveau de sécurité atteint sur les 7 serveurs durcis. Les scores obtenus (77-78/100) attestent d'un niveau de sécurité "bon" selon la classification Lynis, ce qui représente une amélioration significative par rapport à une installation Debian par défaut (généralement autour de 55-60/100).

Serveur	Score Lynis	Tests effectués	Niveau
AUTH	77/100	258	Avancé
DATA	78/100	258	Avancé
BACKUP	77/100	258	Avancé
VPN	77/100	258	Avancé
WEB	78/100	258	Avancé
MAIL	77/100	258	Avancé
LOGS	77/100	255	Avancé
Moyenne	**77.3/100**	–	–
ADMIN, DNS, CLIENT	–	–	Standard (non audité)

Table 2 – Scores de sécurité Lynis par serveur

Les trois serveurs avec sécurité standard (ADMIN, DNS, CLIENT) n'ont pas été audités avec Lynis, mais bénéficient néanmoins d'une protection de base avec pare-feu UFW et AppArmor actifs.

5 Validation et Tests

5.1 Méthodologie de test

Après application du durcissement sur les 7 serveurs critiques, une phase de validation complète a été réalisée pour s'assurer que tous les services restent pleinement opérationnels. Les tests ont été effectués depuis la VM DATA, connectée aux autres VMs via SSH avec authentification par clé publique.

5.2 Tests fonctionnels post-durcissement

Service	**Test effectué**	**Résultat**
OpenLDAP (AUTH)	Recherche d'utilisateurs via ldapsearch	✓ OK
Samba (DATA)	Accès au partage company, création de fichiers	✓ OK
rsnapshot (BACKUP)	Sauvegarde dry-run, vérification rétention (7 daily, 1 weekly)	✓ OK
WireGuard (VPN)	Tunnel établi, 2 peers actifs, routage fonctionnel	✓ OK
Nginx (WEB)	Redirection HTTP→HTTPS, headers de sécurité présents	✓ OK
Postfix/Dovecot (MAIL)	Envoi et réception de mails entre mailuser1 et mailuser2	✓ OK
rsyslog (LOGS)	Réception des logs de 7 VMs dans /var/log/remote/	✓ OK
Unbound (DNS)	Résolution web.secos-gr8.lan → 192.168.100.157	✓ OK

Table 3 – Résultats des tests fonctionnels post-durcissement

5.3 Validation de la centralisation des logs

Le serveur LOGS reçoit correctement les journaux de toutes les VMs configurées. Les logs sont stockés dans des répertoires séparés par hostname (`/var/log/remote/<hostname>/syslog.log`), permettant une analyse centralisée et une détection facilitée des incidents de sécurité.

Cette architecture de logs centralisés facilite également la mise en place future d'un SIEM (Security Information and Event Management) pour l'analyse automatisée des événements de sécurité.

6 Conclusion

6.1 Bilan du projet

Ce projet nous a permis de concevoir et déployer une infrastructure PME complète et fonctionnelle comprenant dix serveurs virtualisés couvrant l'ensemble des besoins d'une entreprise moderne : authentification centralisée (LDAP), stockage partagé (Samba/SFTP), sauvegardes automatisées (rsnapshot), accès distant (VPN WireGuard), présence web sécurisée (Nginx HTTPS), messagerie (Postfix/Dovecot) et supervision (rsyslog centralisé).

Les sept serveurs critiques (AUTH, DATA, BACKUP, VPN, WEB, MAIL, LOGS) ont bénéficié d'un durcissement avancé validé par des scores Lynis de 77-78/100, démontrant une amélioration significative de la posture de sécurité. Les trois serveurs auxiliaires (ADMIN, DNS, CLIENT) disposent d'une sécurité standard avec pare-feu UFW et AppArmor actifs.

Les tests post-durcissement ont confirmé que tous les services restent pleinement opérationnels et interopérables, prouvant qu'il est possible de concilier sécurité renforcée et fonctionnalité.

6.2 Compétences acquises

Ce projet nous a permis de développer des compétences pratiques en :

— Administration système Linux (Debian 12) et virtualisation (Proxmox)

— Configuration de services réseau : LDAP, Samba, DNS, Mail, VPN, Web
— Durcissement système selon les bonnes pratiques (CIS Benchmarks, ANSSI)
— Audit de sécurité avec Lynis et analyse des résultats
— Documentation technique et rédaction de procédures

6.3 Axes d'amélioration pour la production

Pour une mise en production réelle, nous recommandons :

— **Chiffrement LUKS des disques** (non implémenté pour faciliter l'administration)
— Étendre le durcissement avancé aux 3 VMs restantes (ADMIN, DNS, CLIENT)
— Désactiver PasswordAuthentication SSH après déploiement des clés
— Remplacer les mots de passe simples par des mots de passe complexes (12+ caractères)
— Migrer les clients rsyslog vers TLS (serveur LOGS déjà configuré sur port 6514)
— Intégrer une PKI pour remplacer les certificats auto-signés
— Déployer un SIEM pour l'analyse automatisée des logs centralisés

Genève, le 05 janvier 2026